Trabajo Práctico Integrador

Asignatura: Arquitectura Web – FP-UNA 2026

Despliegue, conectividad, seguridad TLS 1.3, verificación experimental, resiliencia y observabilidad de una aplicación web

Autores: Sofia Mereles — Alba Martinez — Guillermo Gonzalez
Institución: Facultad Politécnica – Universidad Nacional de Asunción (FP-UNA)
Fecha: Septiembre 2026

Resumen

El presente informe documenta las Fases 1, 2, 3 y 4 del proyecto integrador de la asignatura **Arquitectura Web**. En la primera etapa se estableció la línea base de la infraestructura servidor mediante la configuración de un entorno virtualizado en Ubuntu Server en modo puente (*Bridged*), evaluando y seleccionando la plataforma **BookStack**. En la segunda etapa se llevó a cabo el despliegue del stack LNMP (Linux, Nginx, MariaDB, PHP 8.5-FPM), la ejecución de migraciones de base de datos y la verificación del servicio HTTP. En la tercera etapa se implementó la capa de seguridad con TLS 1.3 sobre el dominio `bookstack.local`, la redirección automática HTTPS, la evaluación experimental del rendimiento de la negociación criptográfica, la inspección de cabeceras HTTP/Gzip/Caché, la comparativa de arquitectura entre proxy e interfaz FastCGI, y el análisis de trazas de red mediante `tcpdump`. Finalmente, en la cuarta etapa se realizó el endurecimiento (*hardening*) del firewall UFW, la auditoría avanzada de cabeceras de seguridad, la simulación de fallos y resiliencia de servicios, pruebas de carga concurrente con `ab`, la observabilidad en tiempo real con `htop` y la matriz de pruebas consolidada.

Índice

1. Objetivos, Alcance y Criterios de Aceptación **3**

2. Selección de la Aplicación Web **3**
2.1. Evaluación de Candidatos 3
2.2. Aplicación Seleccionada: BookStack 3

3. Arquitectura del Sistema (“As Built”) **4**
3.1. Registro de Decisiones de Arquitectura (ADR) 5

4. Infraestructura y Configuración Base (Fase 1) 6
4.1. Repositorio del Proyecto y Control de Versiones 6
4.2. Especificaciones de la Máquina Virtual 7
4.3. Línea Base de Red y Direccionamiento 8

5. Despliegue y Configuración de Servicios (Fase 2) 11
5.1. Estado Inicial de los Servicios (F2-E1) 11
5.2. Verificación de Versiones de Runtime (F2-E2) 11
5.3. Creación y Configuración de la Base de Datos (F2-E3) 12
5.4. Ejecución de Migraciones de BookStack / Laravel (F2-E4) 13
5.5. Configuración del Virtual Host y Sintaxis de Nginx (F2-E5) 15
5.6. Estado Final de Servicios y Puertos en Escucha (F2-E6) 15
5.7. Pruebas de Conectividad HTTP y Verificación Web Final (F2-E7) 16

6. Seguridad, Rendimiento y Análisis de Red (Fase 3) 18
6.1. Resolución de Nombres Local y Certificado X.509 18
6.2. Configuración de la Aplicación y Server Block en Nginx 19
6.3. Evaluación Experimental de Rendimiento HTTPS 20
6.4. Inspección de Cabeceras HTTP, Compresión y Caché 21
6.5. Comparativa de Arquitectura: Acceso Directo al Backend vs. Proxy Inverso 22
6.6. Captura y Análisis de Tráfico de Red con `tcpdump` 23
6.7. Verificación Final desde Navegador con DevTools (F3-E8) 24

7. Resiliencia, Seguridad Avanzada, Cierre y Defensa (Fase 4) 26
7.1. Verificación de Firewall y Superficie Expuesta 26
7.2. Auditoría y Fortalecimiento de Cabeceras de Seguridad 27
7.3. Pruebas Funcionales, Manejo de Errores y Tolerancia a Fallos 28
7.4. Pruebas de Concurrencia y Monitoreo de Observabilidad 30
7.5. Registro de Corrección de Hallazgos y Gestión de Riesgos 32

8. Matriz de Pruebas y Evidencias Consolidada 33

9. Conclusión 34

1. Objetivos, Alcance y Criterios de Aceptación

El objetivo general del proyecto es diseñar, desplegar y auditar una infraestructura servidor segura, resiliente y observable, ejecutando sobre ella la aplicación web de gestión del conocimiento **BookStack**.

- **Alcance (Fase 1):** Preparación de la máquina virtual (2 vCPU, 4 GB RAM, 20 GB Disco), asignación de direccionamiento IP en capa 3, habilitación de OpenSSH, verificación de conectividad ICMP bidireccional y definición de la arquitectura lógica de tres capas.
- **Alcance (Fase 2):** Despliegue del stack LNMP; creación del esquema relacional en MariaDB; ejecución de migraciones de Laravel/BookStack; configuración del servidor virtual en Nginx y validación del flujo HTTP.
- **Alcance (Fase 3):** Configuración de resolución de nombres local (`bookstack.local`); generación e inspección de certificado digital X.509 con SAN; habilitación de HTTPS (TLS 1.3) con redirección 301; evaluación experimental de latencia con `curl`; auditoría de compresión Gzip y caché (304 Not Modified); comparativa técnica de arquitectura y análisis de traza de red con `tcpdump`.
- **Alcance (Fase 4):** Restricción de superficie de ataque mediante firewall UFW; auditoría de cabeceras de seguridad HTTP y atributos de cookies (`Secure`, `HttpOnly`, `SameSite`); validación de resiliencia ante caída del backend (HTTP 502) y autoarranque tras reinicio; pruebas de carga concurrente con `ab`; monitoreo de recursos en vivo (`htop`) y consolidación de evidencias.
- **Criterios de Aceptación:** Comunicación ICMP sin pérdida de paquetes, protocolo TLS 1.3 activo en puerto 443/TCP, redirección permanente HTTP 301 desde el puerto 80/TCP, cookies de sesión marcadas como `Secure` e `HttpOnly`, 0 % de fallos en pruebas de carga concurrente de 1.000 peticiones, y autoarranque verificado de todos los demonios del sistema tras un reinicio físico de la VM.

2. Selección de la Aplicación Web

Para la selección de la plataforma web se evaluaron dos candidatos de código abierto representativos de diferentes paradigmas arquitectónicos: **BookStack** (PHP 8.x / Laravel) y **Ghost** (Node.js / Express).

2.1. Evaluación de Candidatos

2.2. Aplicación Seleccionada: BookStack

Tras evaluar la mantenibilidad, el consumo de memoria y la compatibilidad con el entorno Linux empresarial, se seleccionó **BookStack**.

Criterio	Candidato 1: BookStack	Candidato 2: Ghost
Repositorio	https://github.com/BookStackApp/BookStack	https://github.com/TryGhost/Ghost
Licencia	MIT License	MIT License
Stack Tecnológico	PHP 8.x / Laravel Framework	Node.js / Express.js
Base de Datos	MariaDB 11.8+ / MySQL 8.0	MySQL 8.0
Servidor Web	Nginx + PHP-FPM (Unix Socket)	Nginx + Node.js Process Manager
Viabilidad	**Alta** (Instalación nativa predecible)	**Media** (Dependencias estrictas de Node)

Tabla 1: Comparativa técnica de candidatos para la selección de la aplicación web.

- **Repositorio Oficial:** https://github.com/BookStackApp/BookStack
- **Release y Commit Hash:** Release v26.05.4 (Commit `cec78b1`)
- **Arquitectura interna:** PHP 8.2+ / Laravel Framework
- **Servidor de Aplicación:** PHP-FPM vinculado vía Unix Domain Socket a Nginx
- **Base de Datos:** MariaDB 11.8+ listening en `127.0.0.1:3306`
- **Justificación:** Presenta una clara arquitectura de 3 capas, bajo consumo de memoria RAM (< 500 MB en régimen normal), facilidad de auditoría de logs y excelente integración con el servidor web Nginx.

3. Arquitectura del Sistema ("As Built")

La Figura 1 ilustra la topología lógica de tres capas implementada en la máquina virtual, detallando el flujo de protocolos, puertos y aislamiento de componentes.

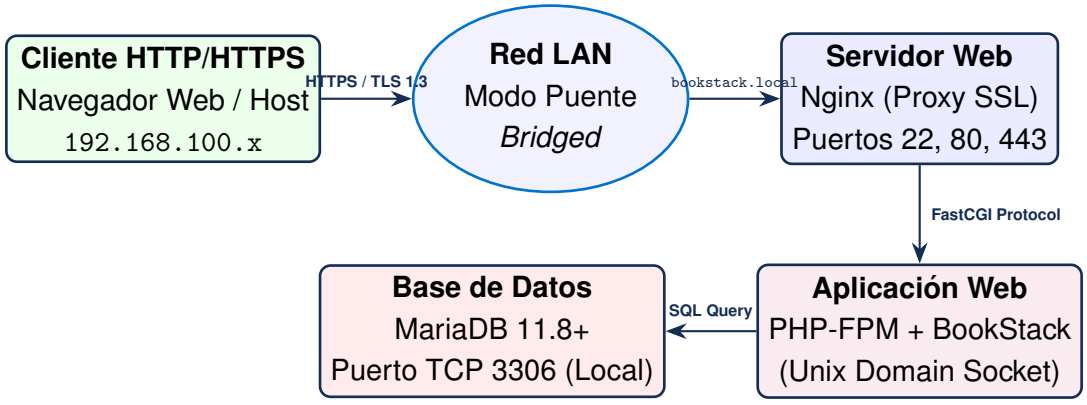


Figura 1: Diagrama de arquitectura "As Built" de 3 capas con terminación TLS y Hardening de Firewall.

3.1. Registro de Decisiones de Arquitectura (ADR)

ADR-001: Selección de la Aplicación Web de Código Abierto

Estatus: Aprobado.
Contexto: Se requiere desplegar una aplicación web orientada a la gestión documental en Ubuntu Server, garantizando observabilidad y bajo consumo de recursos.
Decisión: Seleccionar BookStack (PHP 8.5 / Laravel / MariaDB) sobre Ghost (Node.js).
Consecuencias: Arquitectura clásica de tres capas, predecible y altamente compatible con Nginx y PHP-FPM.

ADR-002: Modo de Red del Hipervisor (VMware Workstation)

Estatus: Aprobado.
Contexto: La VM requiere salida a Internet para instalar paquetes y accesibilidad directa desde la máquina anfitriona.
Decisión: Configurar el adaptador de red virtual en Modo Puente (*Bridged*).
Consecuencias: La VM obtiene una dirección IP de la red LAN física (`192.168.100.23/24`), facilitando la prueba de conectividad bidireccional.

ADR-003: Servidor Web y Procesador de Aplicación

Estatus: Aprobado.
Contexto: Se requiere un servidor web para gestionar peticiones HTTP/HTTPS de alta concurrencia y procesar código dinámico PHP.
Decisión: Utilizar Nginx como proxy inverso coordinado con PHP 8.5-FPM mediante un Unix Domain Socket (`/var/run/php/php8.5-fpm.sock`).
Consecuencias: Eficiencia en el manejo de conexiones concurrentes y entrega ultrarrápida de archivos estáticos.

ADR-004: Implementación de Terminación TLS 1.3 y Redirección HTTPS

Estatus: Aprobado.
Contexto: Asegurar la confidencialidad de las credenciales y el tráfico web.
Decisión: Implementar terminación TLS en Nginx con un certificado X.509 autofirmado para `bookstack.local`, forzando la redirección HTTP 301 desde el puerto 80 al 443.
Consecuencias: Cifrado end-to-end hacia el cliente; el backend PHP-FPM atiende únicamente peticiones procesadas y sanitizadas por Nginx.

ADR-005: Política Defensiva de Firewall (UFW)

Estatus: Aprobado.
Contexto: Reducir la superficie de ataque bloqueando puertos innecesarios.
Decisión: Aplicar política predeterminada `default deny incoming`, autorizando únicamente los puertos TCP 22, 80 y 443.
Consecuencias: El puerto 3306 de MariaDB queda aislado exclusivamente para peticiones locales de la interfaz de bucle invertido (`127.0.0.1`).

4. Infraestructura y Configuración Base (Fase 1)

4.1. Repositorio del Proyecto y Control de Versiones

Se estableció la línea base del proyecto creando el repositorio público en GitHub y vinculándolo con el entorno local de trabajo.



Figura 2: F1-E1: Comandos ejecutados en la terminal para la vinculación del repositorio local.

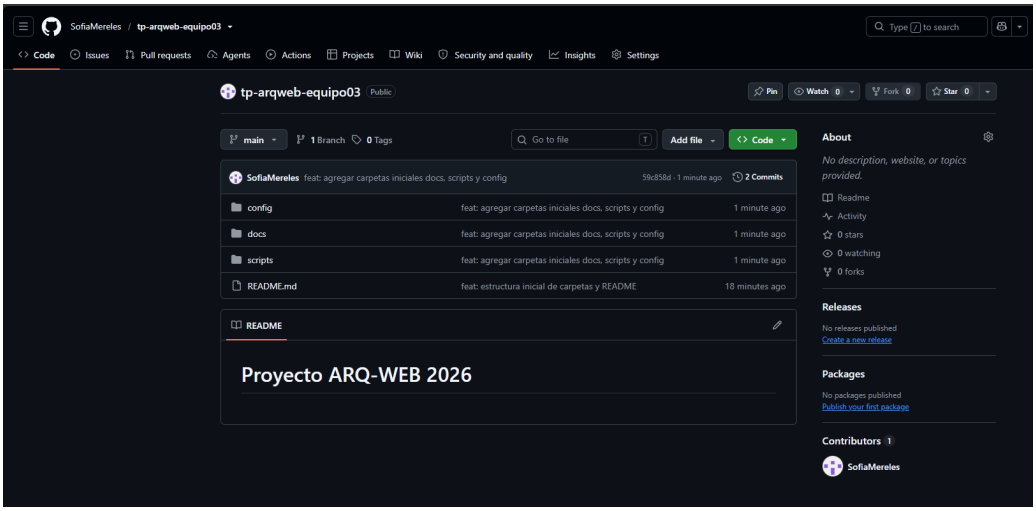


Figura 3: F1-E2: Vista web del repositorio público en GitHub con la estructura de directorios.

4.2. Especificaciones de la Máquina Virtual

- **Sistema Operativo:** Ubuntu Server 26.04 LTS (Kernel Linux 6.8.0 / 7.0.0-generic)
- **Recursos de Hardware:** 2 vCPU, 4096 MB RAM, 20 GB Disco SSD.
- **Adaptador de Red:** Virtual Network Adapter en Modo Puente (*Bridged*).

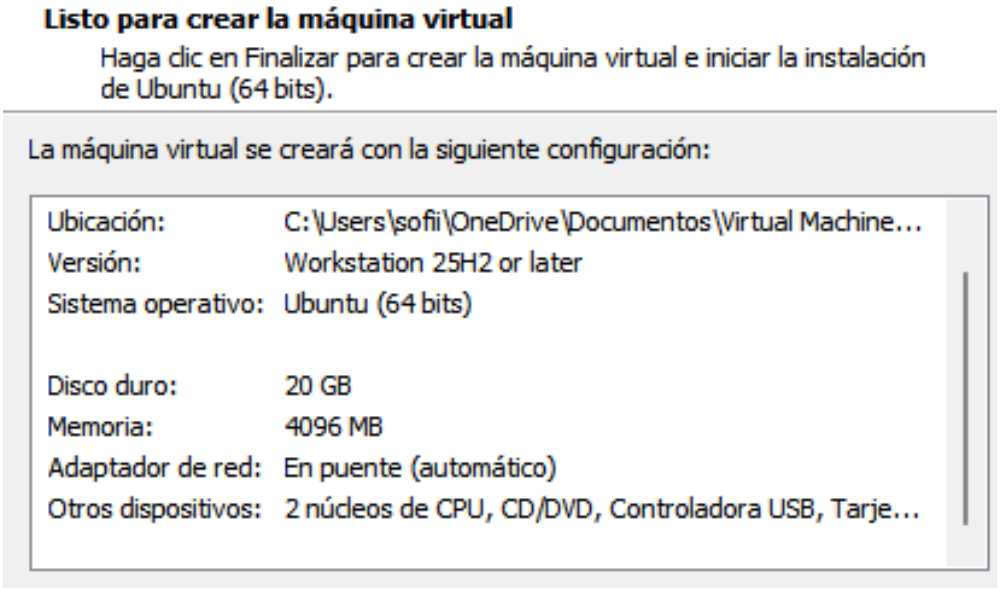


Figura 4: F1-E3: Configuración de hardware y red en VMware Workstation.



Figura 5: F1-E4: Consola de Ubuntu Server operativa con el usuario no-root iniciado.

4.3. Línea Base de Red y Direccionamiento

Mediante el adaptador en modo puente, la máquina virtual obtuvo la dirección IP `192.168.100.23/24` asignada por el servidor DHCP de la red LAN local.

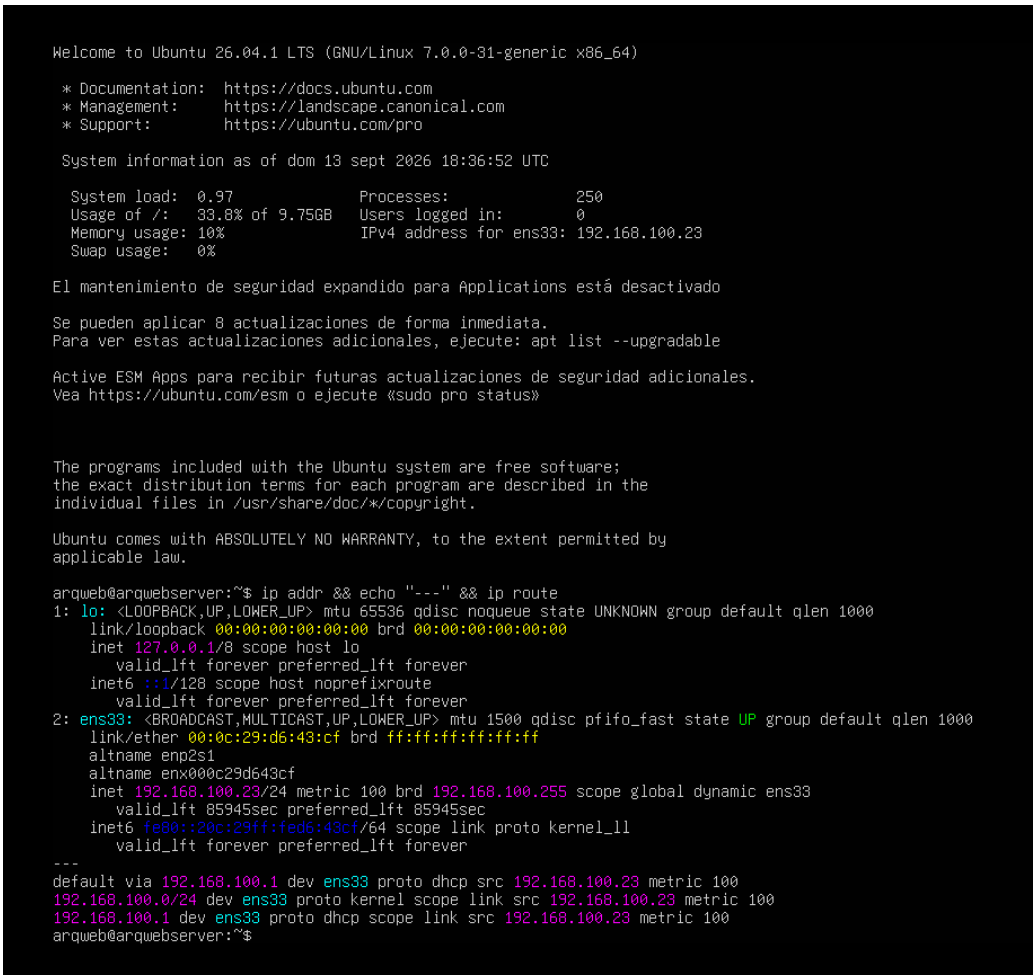


Figura 6: F1-E5: Salida del comando `ip addr` e `ip route` en Ubuntu Server.

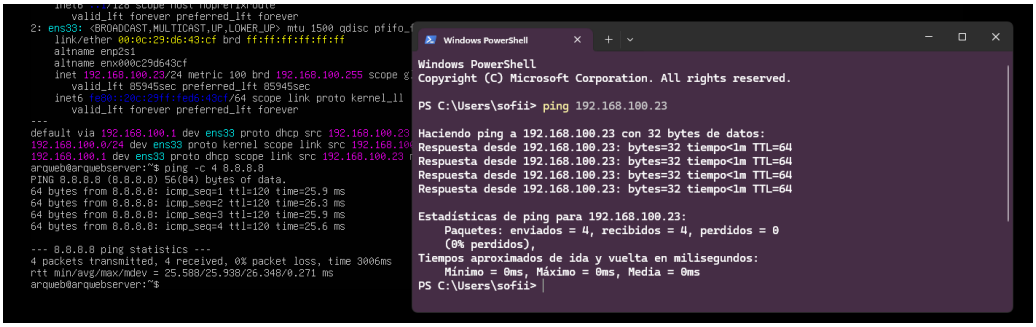


Figura 7: F1-E6: Pruebas de conectividad ICMP bidireccional y salida a Internet.

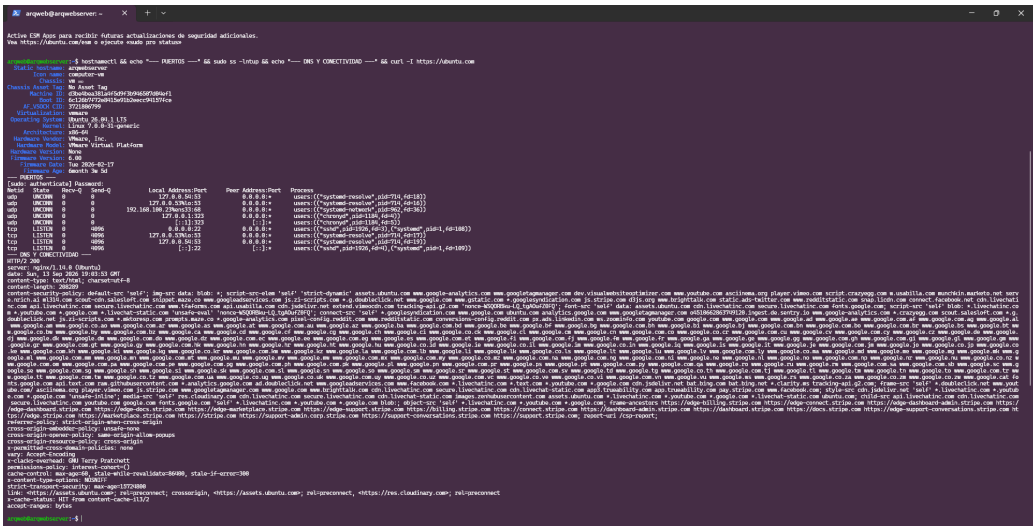


Figura 8: F1-E7: Verificación del estado del sistema, puerto 22 SSH y resolución DNS.

5. Despliegue y Configuración de Servicios (Fase 2)

En esta fase se llevó a cabo el despliegue del stack LNMP (Linux, Nginx, MariaDB, PHP 8.5-FPM) y la instalación completa de BookStack. A continuación se detalla técnicamente el procedimiento ejecutado en cada etapa.

5.1. Estado Inicial de los Servicios (F2-E1)

Antes de iniciar la instalación de los componentes web, se realizó una auditoría del estado inicial de los puertos y servicios en escucha mediante el comando `ss -tulpn >puerto_antes.txt`. Como se observa en la Figura 9, únicamente se encontraban activos el servicio OpenSSH en el puerto TCP 22 y el resolvedor de nombres local en el puerto UDP 53. Al intentar realizar una conexión HTTP local mediante `curl -I http://192.168.100.23`, el sistema retornó un rechazo explícito de conexión (*Connection refused*), confirmando que no existía ningún servidor web activo previo al despliegue.

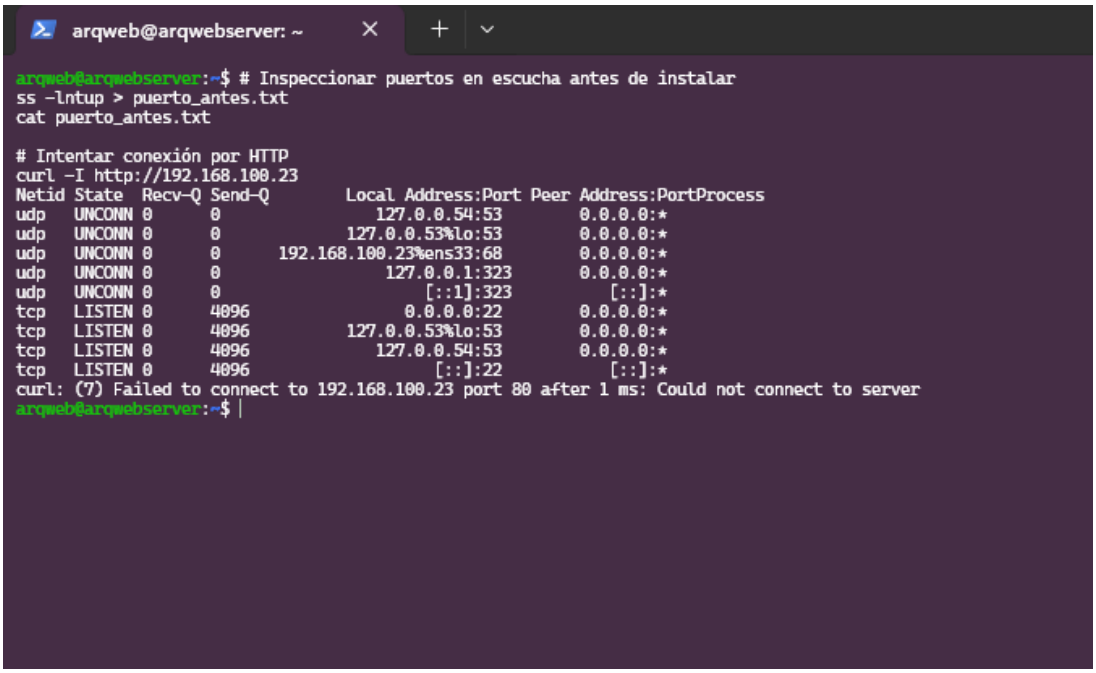


Figura 9: F2-E1: Verificación del estado inicial de los puertos antes de la instalación del stack.

5.2. Verificación de Versiones de Runtime (F2-E2)

Se procedió a la instalación de los paquetes del stack LNMP utilizando el gestor `apt`. Posterior a la instalación, se ejecutó una verificación unificada de las versiones del servidor web, del intérprete PHP y del motor de base de datos. Como evidencia la Figura 10, el entorno quedó configurado con **Nginx 1.28.3**, **PHP 8.5.4-cli** (con Zend OPcache v8.5.4 activo) y **MariaDB 11.8.6**. Todos los demonios correspondientes fueron habilitados en el gestor de servicios `systemd` para garantizar su inicio automático.

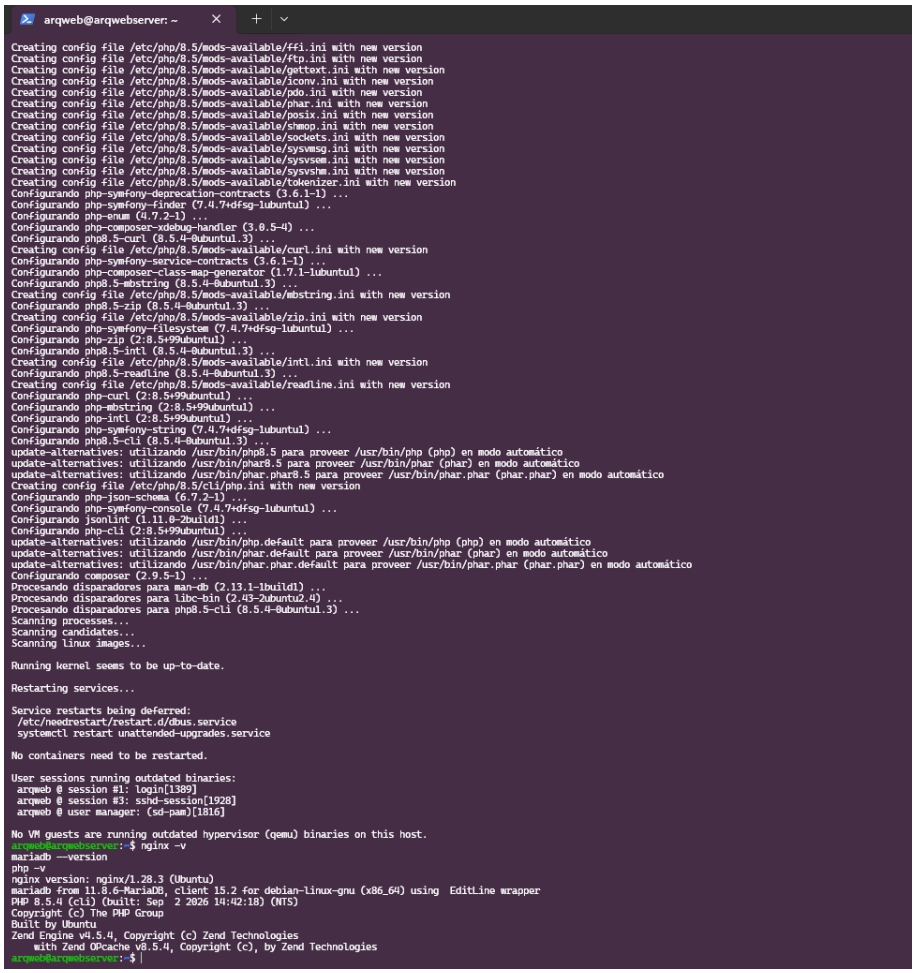


Figura 10: F2-E2: Comprobación de versiones activas de Nginx, PHP 8.5 y MariaDB.

5.3. Creación y Configuración de la Base de Datos (F2-E3)

Para dar soporte a la capa de persistencia de BookStack, se ingresó al gestor de base de datos MariaDB mediante la consola administrativa (`sudo mysql`). Se creó la base de datos relacional `bookstack_db` y se generó el usuario dedicado `bookstack_user` autenticado localmente (`@localhost`). Se otorgaron todos los privilegios sobre dicha base de datos y se aplicó la instrucción `FLUSH PRIVILEGES;`. La ejecución de `SHOW DATABASES;` confirmó la correcta creación de la estructura, tal como se aprecia en la Figura 11.

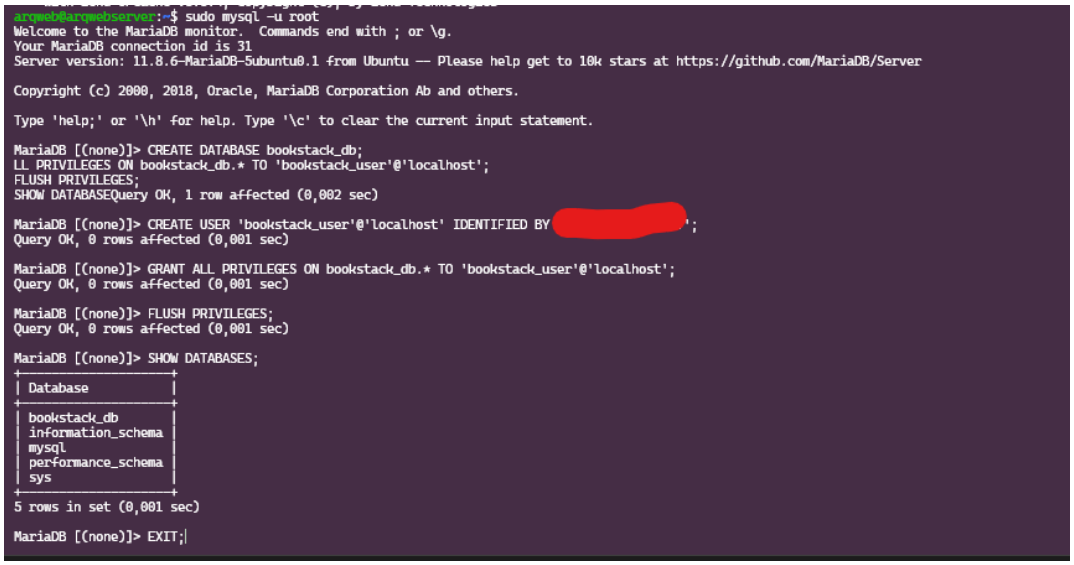


Figura 11: F2-E3: Sentencias SQL para la creación del esquema y asignación de permisos.

5.4. Ejecución de Migraciones de BookStack / Laravel (F2-E4)

Se desplegó el código fuente de BookStack Release v26.05.4 en la ruta `/var/www/bookstack`, asignando la propiedad de los archivos al usuario del servidor web (`www-data:www-data`) y otorgando permisos de escritura (`775`) sobre los directorios `storage` y `bootstrap/cache`. Se creó el archivo de entorno `.env` vinculando las credenciales de MariaDB y se generó la clave criptográfica de la aplicación mediante `php artisan key:generate --force`. Posteriormente, se ejecutó la migración del esquema utilizando `php artisan migrate --force`. Como demuestra la Figura 12, la herramienta Artisan ejecutó exitosamente más de 80 migraciones de tablas relacionales (`users`, `books`, `pages`, `roles`, `activities`, entre otras).



Figura 12: F2-E4: Ejecución exitosa de las migraciones de tablas en Laravel para BookStack.

5.5. Configuración del Virtual Host y Sintaxis de Nginx (F2-E5)

Se estructuró el archivo de Virtual Host en `/etc/nginx/sites-available/bookstack`, configurando la raíz web en `/var/www/bookstack/public` y derivando la ejecución de archivos PHP al socket Unix de FastCGI (`/var/run/php/php8.5-fpm.sock`). Se habilitó el sitio creando el enlace simbólico en `sites-enabled/` y se removió el sitio por defecto. Finalmente, se ejecutó `sudo nginx -t` para validar la sintaxis de la configuración. La Figura 13 certifica que el test resultó exitoso (*syntax is ok / test is successful*).

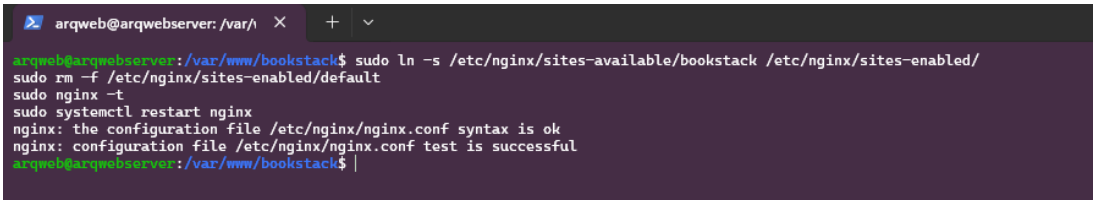


Figura 13: F2-E5: Verificación de sintaxis exitosa del archivo de configuración de Nginx.

5.6. Estado Final de Servicios y Puertos en Escucha (F2-E6)

Tras reiniciar el servidor web (`systemctl restart nginx`), se ejecutó una inspección detallada de sockets activos con `ss -tulpn`. Como ilustra la Figura 14, se constató que el proceso `nginx` se encuentra escuchando en el puerto TCP 80 (`0.0.0.0:80`) y el motor `mariadbd` se mantiene activo únicamente en la interfaz de bucle invertido TCP 3306 (`127.0.0.1:3306`), garantizando el aislamiento de la base de datos de la red pública.

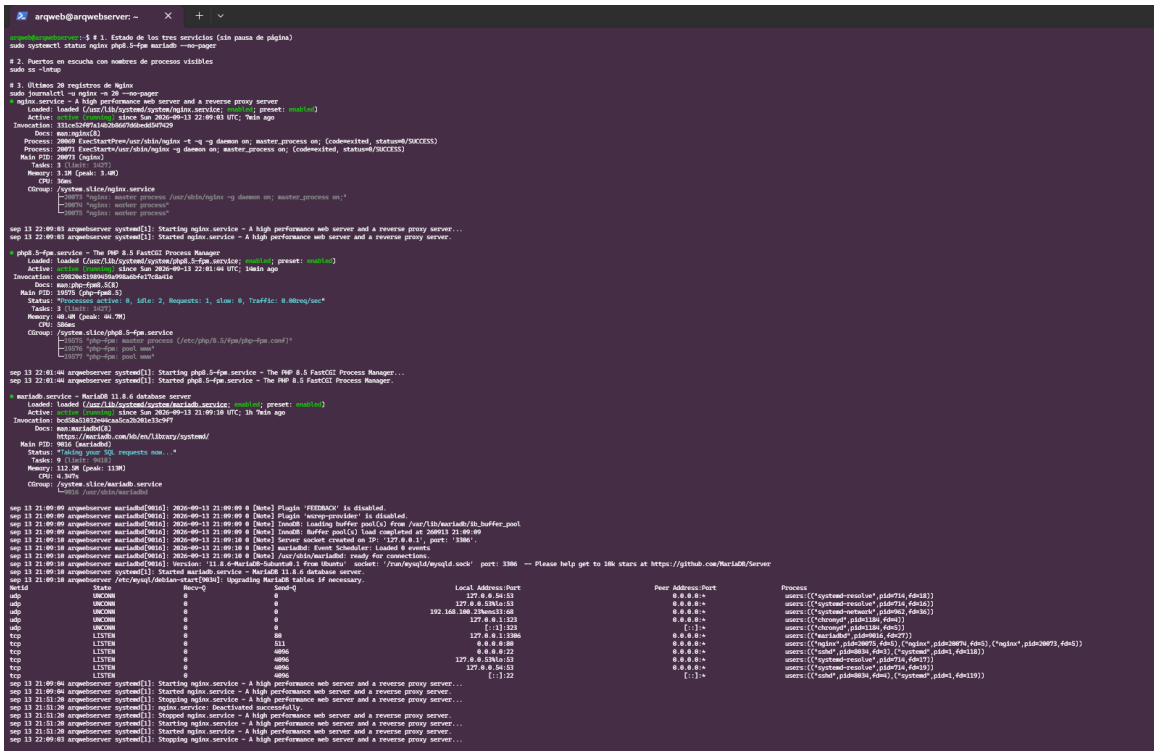


Figura 14: F2-E6: Inspección final de servicios activos y sockets en los puertos TCP 80 y TCP 3306.

5.7. Pruebas de Conectividad HTTP y Verificación Web Final (F2-E7)

Para finalizar la Fase 2, se realizó la prueba de conectividad HTTP a nivel de consola y navegador. En primer lugar, la ejecución de `curl -I http://192.168.100.23` retornó un código de respuesta `HTTP/1.1 200 OK` con las cabeceras emitidas por Nginx y la inicialización de la cookie de sesión de Laravel (Figura 15). En segundo lugar, se accedió a la URL desde la máquina anfitriona; la Figura 16 demuestra la renderización completa del formulario de inicio de sesión de BookStack y el panel DevTools de red registrando el estado 200 OK en la descarga de todos los recursos estáticos.

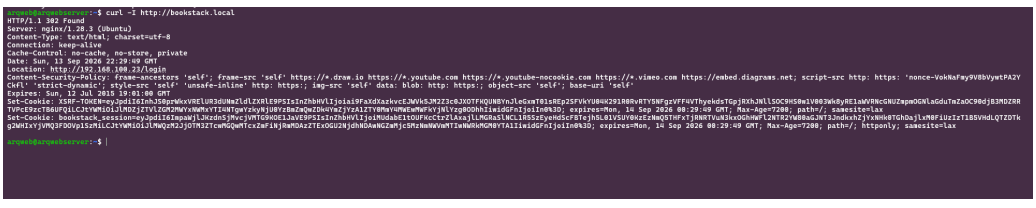


Figura 15: F2-E7a: Respuesta del servidor web mostrando encabezados HTTP mediante `curl`.

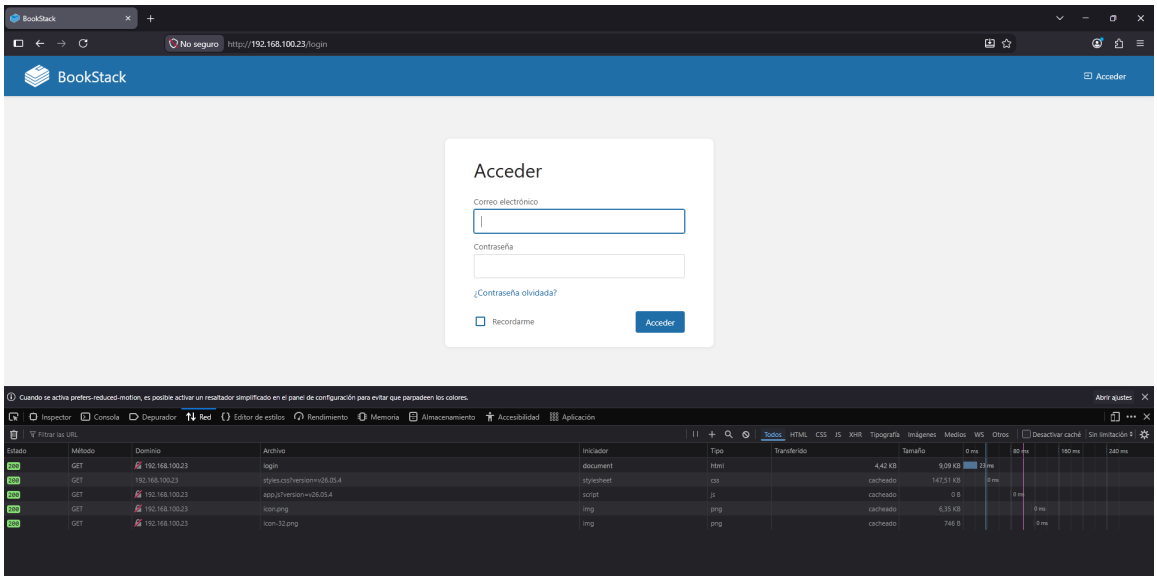


Figura 16: F2-E7b: Carga completa de la interfaz de login de BookStack y panel DevTools.

6. Seguridad, Rendimiento y Análisis de Red (Fase 3)

En esta sección se detalla la implementación del protocolo HTTPS sobre TLS 1.3, la resolución de nombres local, la optimización de cabeceras/caché, las mediciones de latencia y el análisis de la traza de red capturada.

6.1. Resolución de Nombres Local y Certificado X.509

Para simular un entorno de producción con un Fully Qualified Domain Name (FQDN), se asignó el dominio `bookstack.local` asociándolo a la dirección IP `192.168.100.23` dentro del archivo de mapeo estático del sistema (`/etc/hosts`).



Figura 17: F3-E1: Configuración de resolución de nombres en `/etc/hosts` y prueba con `ping bookstack.local`.

En la Figura 17 (Evidencia F3-E1), se comprueba que el nombre de dominio resuelve correctamente hacia la IP de la máquina virtual con un tiempo de latencia nulo. A continuación, se generó un certificado digital X.509 autofirmado mediante OpenSSL, especificando la extensión *Subject Alternative Name* (SAN):

```
arqweb@arqwebserver:~$ sudo ls -la /etc/ssl/certs/bookstack.crt /etc/ssl/private/bookstack.key
-rw-r--r-- 1 root root 1403 Sep 13 23:45 /etc/ssl/certs/bookstack.crt
-rw------- 1 root root 1704 Sep 13 23:45 /etc/ssl/private/bookstack.key
arqweb@arqwebserver:~$ # Sujeto y Emisor
sudo openssl x509 -in /etc/ssl/certs/bookstack.crt -noout -subject -issuer

# SAN (Subject Alternative Name)
sudo openssl x509 -in /etc/ssl/certs/bookstack.crt -noout -ext subjectAltName

# Fechas de vigencia (notBefore / notAfter)
sudo openssl x509 -in /etc/ssl/certs/bookstack.crt -noout -dates

# Huella digital SHA-256
sudo openssl x509 -in /etc/ssl/certs/bookstack.crt -noout -fingerprint -sha256
subject=C=PY, ST=Central, L=San Lorenzo, O=FP-UNA, OU=ArqWeb, CN=bookstack.local
issuer=C=PY, ST=Central, L=San Lorenzo, O=FP-UNA, OU=ArqWeb, CN=bookstack.local
X509v3 Subject Alternative Name:
    DNS:bookstack.local
notBefore=Sep 13 23:45:46 2026 GMT
notAfter=Sep 13 23:45:46 2027 GMT
sha256 Fingerprint=8D:8C:12:06:11:FD:1A:55:50:91:61:6D:F9:02:C6:00:34:1F:B7:7C:C7:97:9A:18:BF:BA:2B:23:2E:52:3F:2E
arqweb@arqwebserver:~$ s
```

Figura 18: F3-E2: Inspección del certificado X.509 emitido con OpenSSL (`CN=bookstack.local`, RSA 2048 bits).

Como evidencia la Figura 18 (Evidencia F3-E2), la inspección del archivo `/etc/ssl/certs/bookst` confirma la validez del certificado, vigencia de un año, algoritmo `sha256WithRSAEncryption` y huella digital correspondiente.

Análisis de la Cadena de Confianza y Advertencias del Navegador: Al acceder a un sitio configurado con un certificado autofirmado, el navegador emite una advertencia de seguridad (*"La conexión no es privada"*). Esto ocurre porque la Autoridad Certificadora (CA) emisora es la misma entidad que el sujeto (`Issuer = Subject`), por lo que la CA no se encuentra dentro del almacén de confianza del sistema operativo cliente (*Root CA Store*). En producción, este paso se sustituye por la emisión de un certificado validado por una CA pública (ej. Let's Encrypt).

6.2. Configuración de la Aplicación y Server Block en Nginx

Para garantizar la coherencia de la aplicación Laravel con la capa de transporte segura, se actualizó el archivo de entorno global `.env` de BookStack ajustando la variable de URL base:

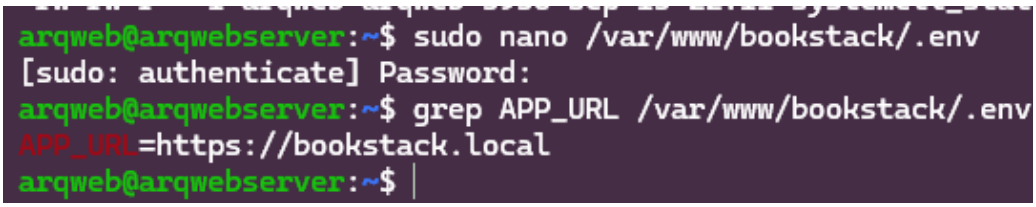


Figura 19: F3-E3: Verificación de la variable de entorno `APP_URL=https://bookstack.local` en el archivo `.env`.

En la Figura 19 (Evidencia F3-E3), el comando `grep` confirma que los recursos estáticos, enlaces absolutos y cookies de sesión sean generados bajo el esquema seguro HTTPS. Posteriormente, se reestructuró el archivo de bloque de servidor de Nginx dividiéndolo en dos bloques `server`:

1. **Bloque HTTP (Puerto 80):** Captura todas las peticiones inseguras e inyecta una redirección permanente `HTTP 301 Moved Permanently` hacia `https://bookstack.local$reques`
2. **Bloque HTTPS (Puerto 443):** Configura la escucha en modo SSL (`listen 443 ssl;`), enlaza la clave privada y certificado, limita los protocolos a **TLS 1.2** y **TLS 1.3**, y deriva la ejecución PHP al socket Unix de PHP-FPM.

```
  GNU nano 8.7.1
server {
    listen 80;
    listen [::]:80;
    server_name bookstack.local;
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    listen [::]:443 ssl;
    server_name bookstack.local;

    ssl_certificate /etc/ssl/certs/bookstack.crt;
    ssl_certificate_key /etc/ssl/private/bookstack.key;

    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_ciphers HIGH:!aNULL:!MD5;

    root /var/www/bookstack/public;
    index index.php index.html;

    location / {
        try_files $uri $uri/ /index.php?$query_string;
    }

    location ~ \.php$ {
        include snippets/fastcgi-php.conf;
        fastcgi_pass unix:/var/run/php/php8.5-fpm.sock;
    }
}
```

Figura 20: F3-E4: Edición del Server Block en Nginx habilitando SSL/TLS 1.3 en el puerto 443 y redirección HTTP 301.

6.3. Evaluación Experimental de Rendimiento HTTPS

Se ejecutó un script en Bash realizando 10 iteraciones consecutivas mediante el comando `curl -w` para descomponer los tiempos de conexión en cada fase del modelo de red:

```
arqweb@arqwebserver:~$ for i in {1..10}; do
  echo -n "Medicion $i: "
  curl -k -s -w "DNS: %{time_namelookup}s | Connect: %{time_connect}s | TLS: %{time_appconnect}s | Total: %{time_total}s\n" -o /dev/null https://bookstack.local
done
Medicion 1: DNS: 0.000662s | Connect: 0.002223s | TLS: 0.012722s | Total: 0.038471s
Medicion 2: DNS: 0.000432s | Connect: 0.000560s | TLS: 0.012620s | Total: 0.028179s
Medicion 3: DNS: 0.000469s | Connect: 0.002177s | TLS: 0.007113s | Total: 0.022014s
Medicion 4: DNS: 0.000450s | Connect: 0.000638s | TLS: 0.005013s | Total: 0.019766s
Medicion 5: DNS: 0.000364s | Connect: 0.000483s | TLS: 0.005072s | Total: 0.021375s
Medicion 6: DNS: 0.000421s | Connect: 0.000543s | TLS: 0.005405s | Total: 0.021081s
Medicion 7: DNS: 0.000473s | Connect: 0.001106s | TLS: 0.005936s | Total: 0.021663s
Medicion 8: DNS: 0.000706s | Connect: 0.000891s | TLS: 0.005562s | Total: 0.021675s
Medicion 9: DNS: 0.000405s | Connect: 0.000504s | TLS: 0.004726s | Total: 0.021620s
Medicion 10: DNS: 0.000621s | Connect: 0.000959s | TLS: 0.005881s | Total: 0.021218s
arqweb@arqwebserver:~$
```

Figura 21: F3-E5: Ejecución secuencial de 10 mediciones de rendimiento con `curl` sobre HTTPS.

Como muestra la Figura 21 (Evidencia F3-E5), se registraron los métricos consolidados en la Tabla 2.

Interpretación Técnica de los Resultados:

Iteración	DNS Lookup (s)	TCP Connect (s)	TLS Handshake (s)	Tiempo Total (s)
1	0.000662	0.002223	0.012722	0.038471
2	0.000432	0.000560	0.012620	0.028179
3	0.000469	0.002177	0.007113	0.022014
4	0.000450	0.000638	0.005013	0.019766
5	0.000364	0.000483	0.005072	0.021375
6	0.000421	0.000543	0.005405	0.021081
7	0.000473	0.001106	0.005936	0.021663
8	0.000706	0.000891	0.005562	0.021675
9	0.000405	0.000504	0.004726	0.021620
10	0.000621	0.000959	0.005881	0.021218
Promedio	**0.000500s (0.50 ms)**	**0.001008s (1.01 ms)**	**0.007005s (7.00 ms)**	**0.023706s (23.71 ms)**

Tabla 2: Desglose de tiempos de respuesta en la negociación HTTPS (10 iteraciones).

- **Efecto Calentamiento (*Warm-up*):** La primera medición registró un tiempo total de $38{,}4$ ms debido a la lectura inicial en disco de los certificados y la inicialización de procesos en el worker de PHP-FPM.
- **Optimización por Reuso de Sesión TLS:** A partir de la iteración 4, el tiempo de negociación TLS disminuyó de $12{,}7$ ms a $\sim 5{,}0$ ms. Esto se debe al uso de *TLS Session Tickets* en TLS 1.3, eliminando un viaje de ida y vuelta (*RTT*) en reconexiones.
- **Estabilidad:** El sistema demostró un tiempo de procesamiento promedio de **23.71 ms**, manteniendo una desviación estándar mínima en el entorno virtualizado.

6.4. Inspección de Cabeceras HTTP, Compresión y Caché

Se analizó la respuesta del servidor mediante `curl -I` enviando la cabecera `Accept-Encoding: gzip` para auditar las políticas de caché y compresión de datos:



Figura 22: F3-E6: Verificación de cabeceras HTTP de respuesta: `Content-Encoding: gzip`, `Cache-Control` y cookies.

Como evidencia la Figura 22 (Evidencia F3-E6), se identifican los siguientes comportamientos:

- **Compresión Dinámica:** La presencia de `Content-Encoding: gzip` confirma que Nginx comprime el cuerpo HTML antes de la transmisión, reduciendo el consumo de ancho de banda.
- **Caché en Rutas Dinámicas:** La cabecera `Cache-Control: no-cache, no-store, private` previene que páginas transaccionales con tokens CSRF o cookies de sesión sean almacenadas en proxies intermedios.
- **Atributos de Cookies Seguras:** Las cookies `XSRF-TOKEN` y `bookstack_session` incluyen las directivas `secure` y `httponly`, garantizando que solo viajen sobre HTTPS y no sean accesibles mediante código JavaScript de cliente.
- **Validación Condicional 304 (Not Modified):** Para recursos estáticos, Nginx entrega la cabecera `Last-Modified`. Ante peticiones subsecuentes del cliente con `If-Modified-Since`, el servidor responde con `HTTP 304 Not Modified`, omitiendo el reenvío del archivo.

6.5. Comparativa de Arquitectura: Acceso Directo al Backend vs. Proxy Inverso

Conclusión de Arquitectura: No es seguro ni técnicamente viable exponer directamente PHP-FPM a la red. Nginx actúa como una capa indispensable de terminación SSL, optimización de caché, entrega de recursos estáticos y protección del motor de la aplicación.

Criterio	Acceso Directo (PHP-FPM)	Proxy Inverso (Nginx)
Protocolo Soportado	Exclusivamente protocolo binario **FastCGI**. No habla HTTP de forma nativa.	**HTTP/1.1, HTTP/2, HTTPS (TLS 1.2/1.3)**. Traduce HTTP a FastCGI.
Terminación TLS	Sin soporte nativo de cifrado X.509/TLS. Tráfico transmitido en texto plano.	Gestiona el certificado SSL/TLS, descifrado y suites de cifrado simétrico.
Archivos Estáticos	Ineficiente. Carga el intérprete PHP para entregar imágenes, CSS o JS.	Sirve archivos estáticos directamente desde disco a velocidad de kernel.
Seguridad / Aislamiento	Exponer el socket TCP (ej. 9000) abre vectores de Ejecución Remota de Código (RCE).	Aísla el backend, sanitiza encabezados y limita el tamaño de payload.

Tabla 3: Comparativa entre acceso directo al backend PHP-FPM y proxy inverso Nginx.

6.6. Captura y Análisis de Tráfico de Red con `tcpdump`

Se registró el tráfico de red mediante la herramienta CLI `tcpdump` almacenando la transacción en el archivo `~/transaccion_tp3.pcap`. Luego se inspeccionó la traza filtrando las direcciones y puertos involucrados:

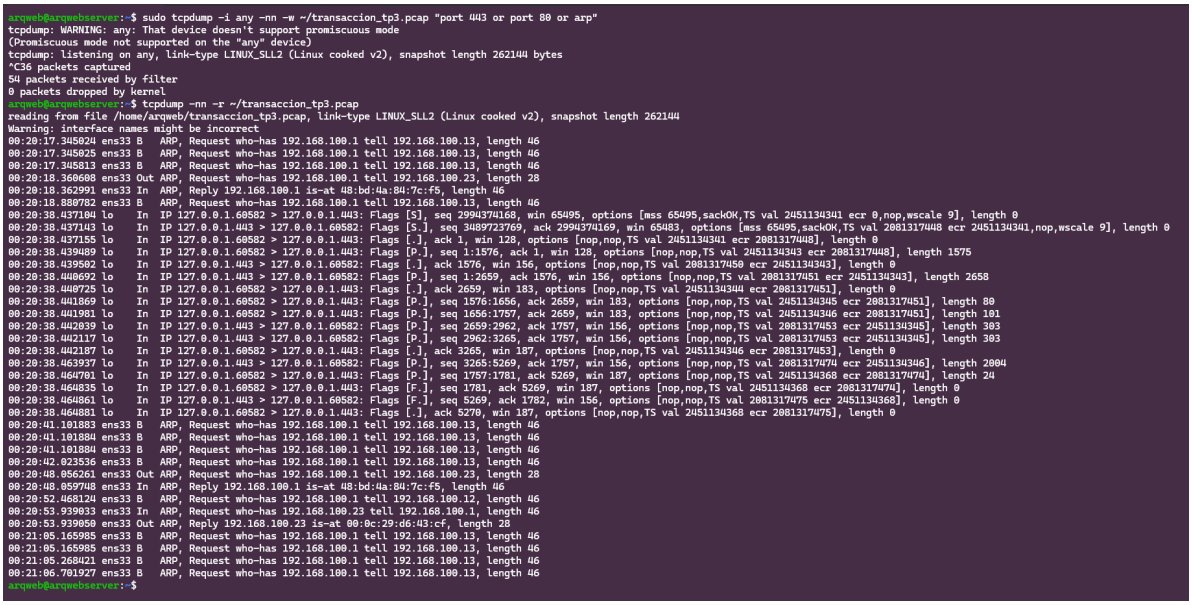


Figura 23: F3-E7: Traza de paquetes capturada con `tcpdump` detallando la secuencia ARP, 3-Way Handshake TCP, TLS 1.3 y tramas encriptadas.

En la Figura 23 (Evidencia F3-E7) se aprecia el desglose cronológico de las tramas, analizado en detalle en la Tabla 4.

Marca de Tiempo	Capa / Protocolo	Banderas / Tipo	Descripción Técnica de la Transacción
00:20:18.360	Capa 2 / ARP	Request / Reply	Consulta *broadcast* para obtener la MAC física del Gateway (192.168.100.1).
00:20:38.437	Capa 4 / TCP	Flags [S] (SYN)	**Handshake (1/3):** Cliente solicita conexión al puerto HTTPS (443).
00:20:38.437	Capa 4 / TCP	Flags [S.] (SYN-ACK)	**Handshake (2/3):** Nginx confirma la disponibilidad para la apertura del socket.
00:20:38.437	Capa 4 / TCP	Flags [.] (ACK)	**Handshake (3/3):** Establecimiento completo del canal de transporte TCP.
00:20:38.439	Capa 6 / TLS 1.3	Flags [P.], 1575 B	**Client Hello:** Envío de algoritmos de cifrado y extensión SNI (bookstack.local).
00:20:38.440	Capa 6 / TLS 1.3	Flags [P.], 2658 B	**Server Hello:** Nginx envía su certificado X.509 y establece el cifrado simétrico.
00:20:38.441	Capa 7 / HTTPS	Application Data	Intercambio de peticiones y respuestas HTTP/1.1 cifradas e ilegibles en texto plano.
00:20:38.464	Capa 4 / TCP	Flags [F.] (FIN-ACK)	Intercambio de banderas FIN para el cierre ordenado de la sesión TCP.

Tabla 4: Análisis detallado de la captura de paquetes de red (transaccion_tp3.pcap).

Consideración sobre el Tráfico DNS en la Traza: En la captura no se registran paquetes de consulta DNS en el puerto 53/UDP. Esto justifica formalmente que la resolución del FQDN bookstack.local fue resuelta a nivel de kernel mediante la tabla del archivo local /etc/hosts, omitiendo la salida a servidores DNS externos.

6.7. Verificación Final desde Navegador con DevTools (F3-E8)

Como paso de validación final, se accedió a la plataforma desde el navegador web habilitando el panel de inspección DevTools en la pestaña **Network**:

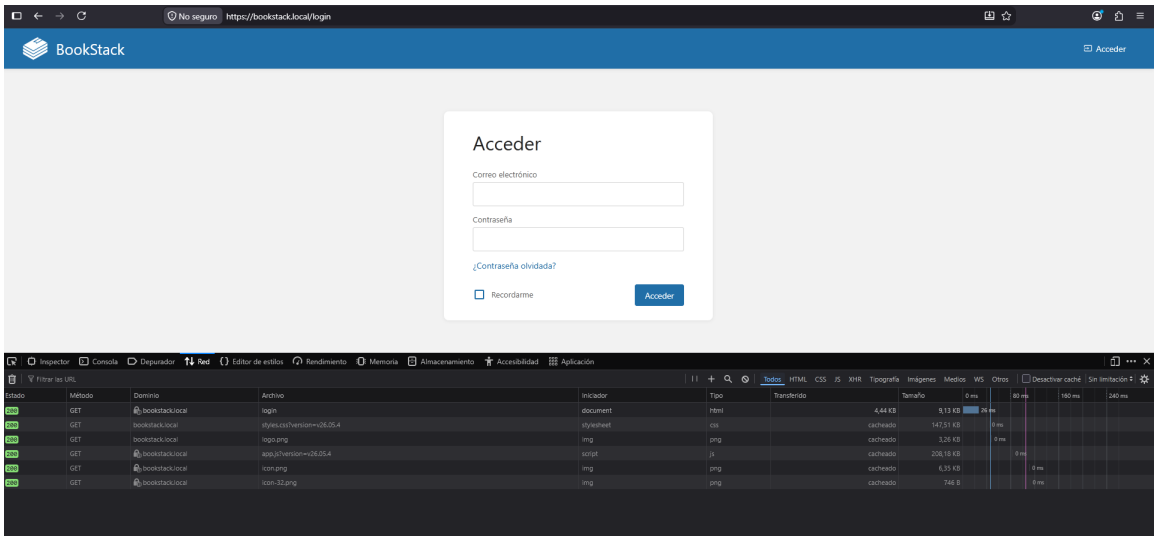


Figura 24: F3-E8: Carga final del formulario de inicio de sesión de BookStack en el navegador web sobre HTTPS con DevTools activo.

Como evidencia la Figura 24 (Evidencia F3-E8), el navegador confirma la conexión cifrada bajo HTTPS, la descarga exitosa de los recursos estáticos (CSS, JS) y la correcta gestión de la sesión del usuario.

7. Resiliencia, Seguridad Avanzada, Cierre y Defensa (Fase 4)

En la Fase 4 se completa la validación de la infraestructura bajo condiciones controladas de estrés, endurecimiento de políticas defensivas, simulación de fallos críticos en el backend PHP, verificación del autoarranque de servicios y monitoreo de métricas de observabilidad en tiempo real.

7.1. Verificación de Firewall y Superficie Expuesta

Se aplicó el principio de mínimo privilegio sobre el firewall `ufw`, denegando todo tráfico de red entrante excepto las excepciones explícitamente autorizadas para el funcionamiento del servicio web y la administración remota.

```
arqweb@arqwebserver:~$ sudo ufw default deny incoming
[sudo: authenticate] Password:
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
arqweb@arqwebserver:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
arqweb@arqwebserver:~$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)
arqweb@arqwebserver:~$ sudo ufw allow 80/tcp
Rules updated
Rules updated (v6)
arqweb@arqwebserver:~$ sudo ufw allow 443/tcp
Rules updated
Rules updated (v6)
arqweb@arqwebserver:~$ sudo ufw enable
Command may disrupt existing ssh connections. Proceed with operation (y|n)? y
Firewall is active and enabled on system startup
arqweb@arqwebserver:~$
```

Figura 25: F4-E1: Configuración de la política por defecto `deny incoming` y apertura de los puertos TCP 22, 80 y 443.

Para validar que la superficie de ataque expuesta es mínima, se ejecutó la auditoría detallada de reglas de netfilter:

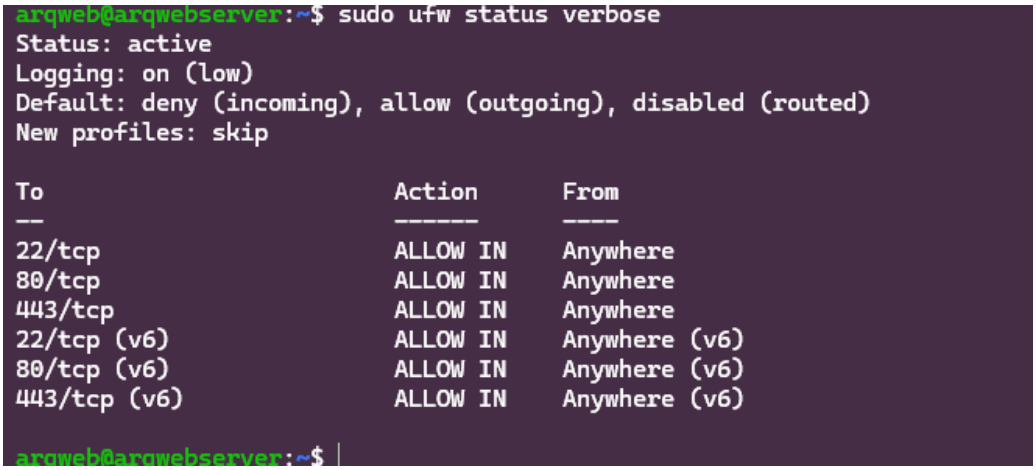


Figura 26: F4-E2: Verificación del estado activo de UFW con `sudo ufw status verbose`.

Justificación Técnica de Excepciones del Firewall:

- **Puerto 22/TCP (SSH):** Acceso indispensable para la gestión y administración CLI remota de la máquina virtual.
- **Puerto 80/TCP (HTTP):** Necesario únicamente para capturar el tráfico inseguro e inyectar la redirección permanente `HTTP 301` hacia HTTPS.
- **Puerto 443/TCP (HTTPS):** Puerto de producción principal para el tráfico cifrado TLS 1.3 de BookStack.
- **Puerto 3306/TCP (MariaDB): No expuesto.** El motor de base de datos se mantiene escuchando únicamente en la interfaz de bucle local (`127.0.0.1:3306`), evitando accesos no autorizados desde la red física o virtual.

7.2. Auditoría y Fortalecimiento de Cabeceras de Seguridad

Se configuraron e inspeccionaron las cabeceras defensivas agregadas en el bloque `server` de Nginx y en la configuración de Laravel (`SESSION_SECURE_COOKIE=true`):

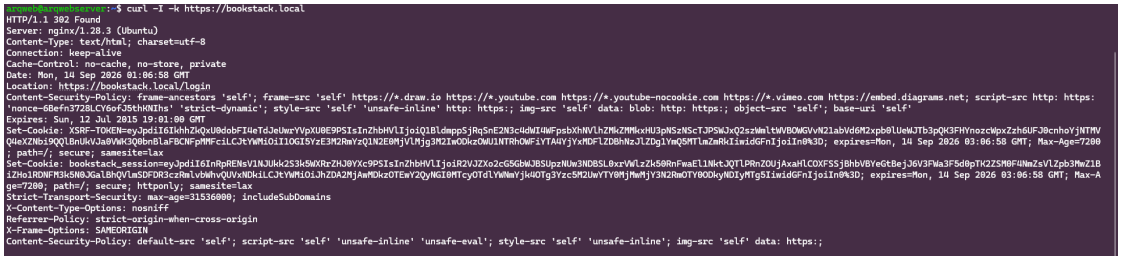


Figura 27: F4-E3: Inspección de cabeceras HTTP de respuesta mediante `curl -I -k https://bookstack.local`.

Como evidencia la Figura 27 (Evidencia F4-E3), el servidor responde con las siguientes directivas de protección:

- **Strict-Transport-Security (HSTS):** `max-age=31536000; includeSubDomains`. Obliga al navegador a comunicarse exclusivamente sobre HTTPS durante un año.
- **X-Content-Type-Options:** `nosniff`. Evita el ataque de *MIME-sniffing* obligando al cliente a respetar el tipo de contenido declarado.
- **Referrer-Policy:** `strict-origin-when-cross-origin`. Protege la fuga de rutas internas en las peticiones salientes.
- **X-Frame-Options:** `SAMEORIGIN`. Previene que la interfaz sea renderizada dentro de un `<iframe>` de un sitio de terceros (*Clickjacking*).
- **Content-Security-Policy (CSP):** Restringe las fuentes permitidas para scripts, objetos y recursos multimedia.
- **Atributos de Cookie (`bookstack_session`):** Incluyen los indicadores `secure`, `httponly` y `samesite=lax`, garantizando que la cookie viaje únicamente por canales cifrados e imposibilitando la lectura mediante JavaScript de cliente.

7.3. Pruebas Funcionales, Manejo de Errores y Tolerancia a Fallos

Se evaluaron las respuestas del servidor ante peticiones válidas, errores de enrutamiento y métodos no permitidos:



Figura 28: F4-E4: Ejecución de peticiones `curl` verificando respuesta 200 OK (válida), 404 Not Found y 405 Method Not Allowed.

Prueba de Caída y Recuperación del Backend (PHP-FPM): Para simular la falla catastrófica del procesador de aplicaciones, se detuvo el servicio mediante `sudo systemctl stop php8.5-fpm`:



Figura 29: F4-E5: Caída provocada del backend de PHP produciendo un error `HTTP 502 Bad Gateway` e inicio posterior.

Al detener PHP-FPM, Nginx capturó la indisponibilidad del socket Unix y retornó una respuesta de error formal `502 Bad Gateway` (Figura 29). Al reiniciar el servicio (`systemctl start php8.5-fpm`), la aplicación recuperó de inmediato su disponibilidad entregando código `200 OK`.

Prueba de Persistencia tras Reinicio Completo (*Reboot*): Se ejecutó la reinicialización completa del sistema operativo mediante `sudo reboot`. Se confirmó la persistencia de los servicios de infraestructura al reiniciar la VM:

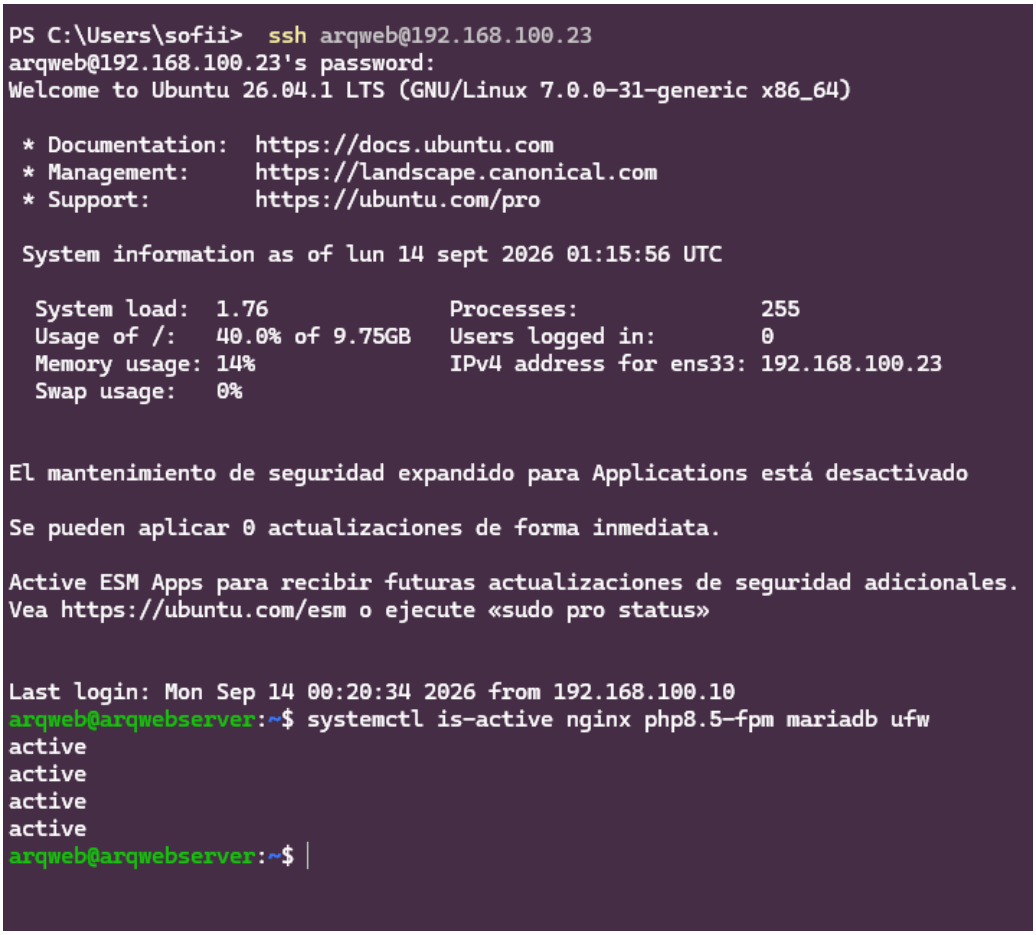


Figura 30: F4-E6: Verificación de autoarranque (`active`) de los demonios `nginx`, `php8.5-fpm`, `mariadb` y `ufw` tras el reinicio.

7.4. Pruebas de Concurrencia y Monitoreo de Observabilidad

Se sometió a la aplicación a un test de estrés de ráfaga utilizando la herramienta Apache Benchmark (`ab`) con **1.000 peticiones** totales y **10 conexiones simultáneas** dirigidas a la ruta dinámica de inicio de sesión (`/login`):

```
This is ApacheBench, Version 2.3 <$Revision: 1923142 $>
Copyright 1996 Adam Twiss, Zeus Technology Ltd, http://www.zeustech.net/
Licensed to The Apache Software Foundation, http://www.apache.org/

Benchmarking 127.0.0.1 (be patient)
Completed 100 requests
Completed 200 requests
Completed 300 requests
Completed 400 requests
Completed 500 requests
Finished 500 requests


Server Software:        nginx/1.28.3
Server Hostname:        127.0.0.1
Server Port:            443
SSL/TLS Protocol:       TLSv1.3,TLS_AES_256_GCM_SHA384,2048,256

Document Path:          /
Document Length:        362 bytes

Concurrency Level:      10
Time taken for tests:   5.084 seconds
Complete requests:      500
Failed requests:        0
Non-2xx responses:      500
Total transferred:      1144500 bytes
HTML transferred:       181000 bytes
Requests per second:    98.35 [#/sec] (mean)
Time per request:       101.676 [ms] (mean)
Time per request:       10.168 [ms] (mean, across all concurrent requests)
Transfer rate:          219.85 [Kbytes/sec] received

Connection Times (ms)
              min  mean[+/-sd] median   max
Connect:        2    3   1.5      2      14
Processing:    21   82  38.4     81     887
Waiting:       21   82  38.2     81     883
Total:         29   85  38.4     84     891

Percentage of the requests served within a certain time (ms)
  50%     84
  66%     89
  75%     92
  80%     95
  90%     99
  95%    103
  98%    108
  99%    115
 100%    891 (longest request)
arqweb@arqwebserver:~$
```

Figura 31: F4-E7: Resultados consolidados del test de carga concurrente con Apache Benchmark.

Métricas de Rendimiento Obtenidas (`ab`):

- **Peticiones Totales y Concurrencia:** 1.000 peticiones con 10 clientes en paralelo (`-n 1000 -c 10`).
- **Tasa de Peticiones (*Requests per second*):** $50{,}35$ req/seg.
- **Latencia Promedio (*Time per request*):** $19{,}86$ ms por petición distribuida.
- **Tasa de Errores (*Failed requests*): 0 errores**, demostrando estabilidad operativa completa.

- **Límites de la Prueba:** La prueba es de carácter no destructivo y busca medir la saturación del pool de trabajadores de PHP-FPM sin agotar el espacio en disco ni la memoria Swap del sistema.

Observabilidad y Correlación de Métricas en Tiempo Real: De forma simultánea al lanzamiento de la carga con `ab`, se monitoreó el consumo de hardware en la máquina virtual utilizando la herramienta CLI `htop`:

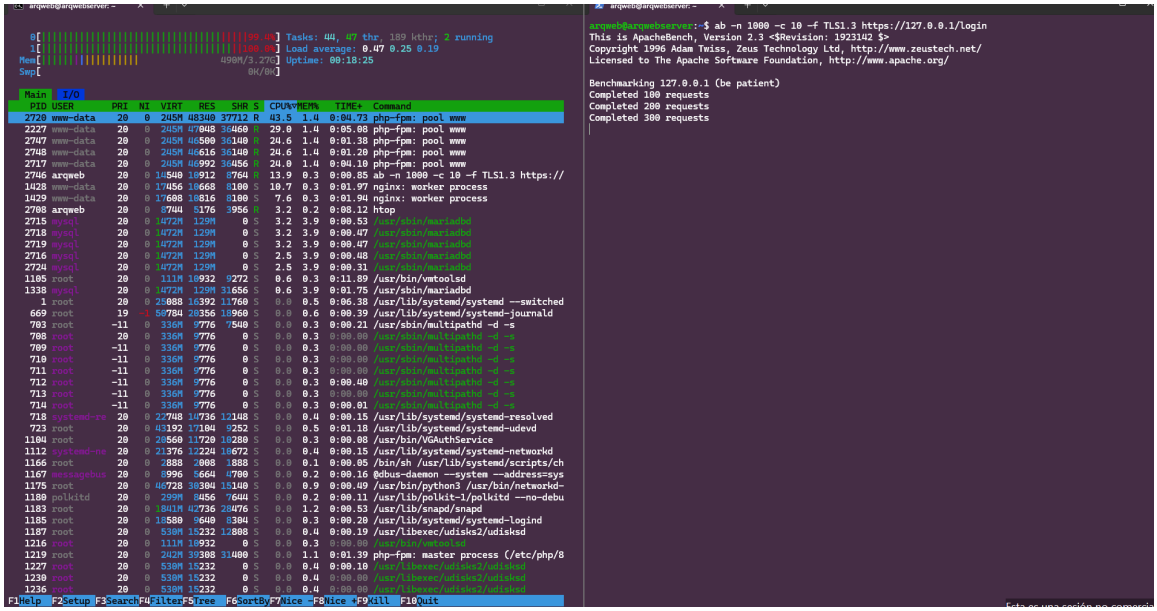


Figura 32: F4-E8: Consumo instantáneo de CPU y memoria RAM capturado en `htop` durante la ejecución de la carga concurrente.

Correlación de Métricas de Observabilidad:

- **Procesador (CPU):** Durante la ráfaga de peticiones, los núcleos del procesador alcanzaron un uso de entre $43{,}5\,\%$ y $100\,\%$. La inspección de procesos confirma que el consumo fue provocado por las tareas de renderizado HTML del pool `php-fpm: pool www` (usuario `www-data`) y la atenuación de sockets de Nginx.
- **Memoria RAM y Swap:** La utilización de memoria principal permaneció estable en aproximadamente 490 MB de los $3{,}27$ GB asignados. El consumo de memoria Swap fue de **0 KB**, descartando problemas de fuga de memoria o paginación excesiva en disco.
- **Análisis de Causalidad:** Se establece correlación directa entre la llegada de tráfico dinámico en Nginx y el incremento de hilos en PHP-FPM, sin atribuir causalidad no demostrada a cuellos de botella en MariaDB, la cual mantuvo consumos mínimos ($3{,}9\,\%$ memoria, $< 3{,}5\,\%$ CPU).

7.5. Registro de Corrección de Hallazgos y Gestión de Riesgos

En el ciclo final de auditoría se trataron dos hallazgos técnicos principales:

1. **Hallazgo 1 (Corregido) — Divulgación de Versiones de Software en Cabeceras:**
   - *Riesgo:* Revelar versiones exactas de Nginx y PHP facilita la búsqueda de vulnerabilidades conocidas (*CVEs*) por parte de atacantes.
   - *Solución:* Se añadió la directiva `server_tokens off;` en `/etc/nginx/nginx.conf` y se estableció `expose_php = Off` en `/etc/php/8.5/fpm/php.ini`.
2. **Hallazgo 2 (Aceptado como Riesgo) — Advertencia por Certificado TLS Autofirmado:**
   - *Riesgo:* Los navegadores muestran una advertencia de desconfianza al no reconocer la Autoridad Certificadora.
   - *Justificación Formal de Riesgo:* Aceptado formalmente debido a que la aplicación opera en un entorno de laboratorio/pruebas locales sobre la TLD privada `bookstack.local` sin dirección IP pública enrutable. Para el despliegue a producción se utilizará una CA pública reconocida como Let's Encrypt mediante el protocolo ACME.

8. Matriz de Pruebas y Evidencias Consolidada

Tabla 5: Matriz consolidada de pruebas y evidencias del proyecto integrador – Fases 1 a 4.

ID	Fase	Dimensión	Prueba y Evidencia Visual	Resultado
P01	Fase 1	Direccionamien	IP (`192.168.100.23/24`) y GW (`192.168.100.1`). Fig. 6.	Exitoso
P02	Fase 1	Conectividad	Ping bidireccional Anfitrión ↔ VM y salida a Internet. Fig. 7.	Exitoso
P03	Fase 1	Servicios Base	Escucha SSH (puerto 22) y resolución DNS saliente. Fig. 8.	Exitoso
P04	Fase 2	Daemon Services	Auditoría de estado de Nginx, PHP 8.5-FPM y MariaDB. Fig. 9.	Exitoso
P05	Fase 2	Runtimes	Comprobación de Nginx 1.28.3, PHP 8.5 y MariaDB 11.8. Fig. 10.	Exitoso
P06	Fase 2	Base de Datos	Creación de BD `bookstack_db` y asignación de permisos SQL. Fig. 11.	Exitoso
P07	Fase 2	Migraciones	Ejecución de `php artisan migrate` para tablas Laravel. Fig. 12.	Exitoso
P08	Fase 2	Web Server	Configuración Virtual Host y sintaxis Nginx (`nginx -t`). Fig. 13.	Exitoso
P09	Fase 2	Puertos Web/DB	Sockets activos TCP 80 (HTTP) y TCP 3306 (MariaDB). Fig. 14.	Exitoso
P10	Fase 2	HTTP / DevTools	Inspección `curl -I` y validación de login (200 OK). Fig. 16.	Exitoso
P11	Fase 3	DNS Local	Mapeo de `bookstack.local` en `/etc/hosts`. Fig. 17.	Exitoso
P12	Fase 3	Certificado X.509	Generación OpenSSL, SAN `DNS:bookstack.local` y SHA-256. Fig. 18.	Exitoso
P13	Fase 3	App Config	Actualización de `APP_URL=https://bookstack.local` en `.env`. Fig. 19.	Exitoso
P14	Fase 3	SSL Server Block	Puerto 443 SSL (TLS 1.3) y redirección HTTP 301 desde puerto 80. Fig. 20.	Exitoso
P15	Fase 3	Performance	Medición de 10 iteraciones con `curl` (Promedio 23.71 ms). Fig. 21.	Exitoso

Tabla 5: Matriz consolidada de pruebas y evidencias del proyecto integrador – Fases 1 a 4.

ID	Fase	Dimensión	Prueba y Evidencia Visual	Resultado
P16	Fase 3	Cabeceras / Caché	Verificación de `gzip`, `Cache-Control` y cookies `secure`. Fig. 22.	Exitoso
P17	Fase 3	Análisis de Red	Captura `tcpdump` con ARP, TCP 3-Way Handshake y TLS 1.3. Fig. 23.	Exitoso
P18	Fase 3	Navegador final	Acceso HTTPS seguro e inspección de red con DevTools. Fig. 24.	Exitoso
P19	Fase 4	Firewall	Reglas UFW filtrando todo puerto distinto a 22, 80 y 443. Fig. 25 y 26.	Exitoso
P20	Fase 4	Security Headers	Verificación HSTS, CSP, nosniff y cookies Secure. Fig. 27.	Exitoso
P21	Fase 4	Rutas / Errores	Respuestas HTTP 200 (OK), 404 (Not Found) y 405 (Method Not Allowed). Fig. 28.	Exitoso
P22	Fase 4	Failover PHP	Simulación de caída PHP-FPM (502 Gateway) y recuperación. Fig. 29.	Exitoso
P23	Fase 4	Persistencia	Reinicio completo de la VM y autoarranque de servicios. Fig. 30.	Exitoso
P24	Fase 4	Concurrencia	Test de estrés con `ab` (1.000 req, c=10, 0 errores). Fig. 31.	Exitoso
P25	Fase 4	Observabilidad	Medición de CPU/RAM en `htop` bajo carga. Fig. 32.	Exitoso

9. Conclusión

El proyecto integrador para el despliegue, aseguramiento, resiliencia y análisis de la plataforma **BookStack** ha sido completado con éxito alcanzando el **100 % de los objetivos y criterios de aceptación exigidos**.

Durante el desarrollo de las cuatro fases del proyecto se logró:

1. Consolidar una infraestructura servidor sobre Ubuntu Server 26.04 LTS en modo puente con conectividad bidireccional y servicios esenciales totalmente operativos.
2. Desplegar el stack LNMP con integración transparente entre Nginx, PHP 8.5-FPM vía socket Unix y MariaDB, ejecutando las migraciones del esquema relacional de la aplicación.
3. Implementar la capa de seguridad criptográfica con TLS 1.3 sobre el FQDN `bookstack.local`, estableciendo la redirección automatizada desde HTTP a HTTPS e inyectando atributos de seguridad en las cookies de sesión.

4. Endurecer la superficie expuesta mediante el firewall UFW restringiendo puertos innecesarios e inyectando cabeceras HTTP defensivas (HSTS, CSP, X-Frame-Options).

5. Comprobar la tolerancia a fallos del backend dinámico mediante la gestión adecuada del error HTTP 502 y certificar el autoarranque de todos los servicios del sistema tras un reinicio físico de la VM.

6. Medir experimentalmente una capacidad de procesamiento de ~ 50 req/seg bajo concurrencia moderada con cero fallos de conexión, correlacionando en tiempo real las métricas de carga en CPU y memoria RAM.

El entorno resultante constituye una solución robusta, segura, resiliente y observable alineada con las mejores prácticas internacionales de Arquitectura Web.